

Information Security

Unit- 4 Authentication

Authentication :

- Authentication is the process of verifying the identity of user or information. It uses information provided to the authenticator to determine whether someone (or something) is, in fact, who (or what) it is declared to be.
- Authentication process can be described in two distinct phases: identification and actual authentication (verification).

1. Identification Phase :

- Identification phase provides a user identity to the security system. This identity is provided in the form of a userID. The security system will search all the abstract objects that it knows and find the specific one of which the actual user is currently applying. Once this is done, the user has been identified.

2. Verification Phase :

- The fact that the user claims does not necessarily mean that this is true. An actual user can be mapped to other abstract user object in the system, and therefore be granted rights and permissions to the user and user must give evidence to prove his identity to the system.
- The process of determining claimed user identity by checking user-provided evidence is called authentication and the evidence which is provided by the user during process of authentication is called a credential.

- There are 4- general means of authenticating a user's identity, which can be used alone or in combination.

1. Something the individual knows:

Password, a personal identification number (PIN)

2. Something the individual possesses :

Cryptographic keys, electronic keycards, smart cards, and physical keys.

3. Something the individual is (static biometrics) :

Recognition by fingerprint, retina, and face.

4. Something the individual does (dynamic biometrics) :

Recognition by voice pattern, handwriting characteristics, and typing rhythm.

Types of Authentication

- There are two basic types of authentication:

1. Non - repudiable Authentication :

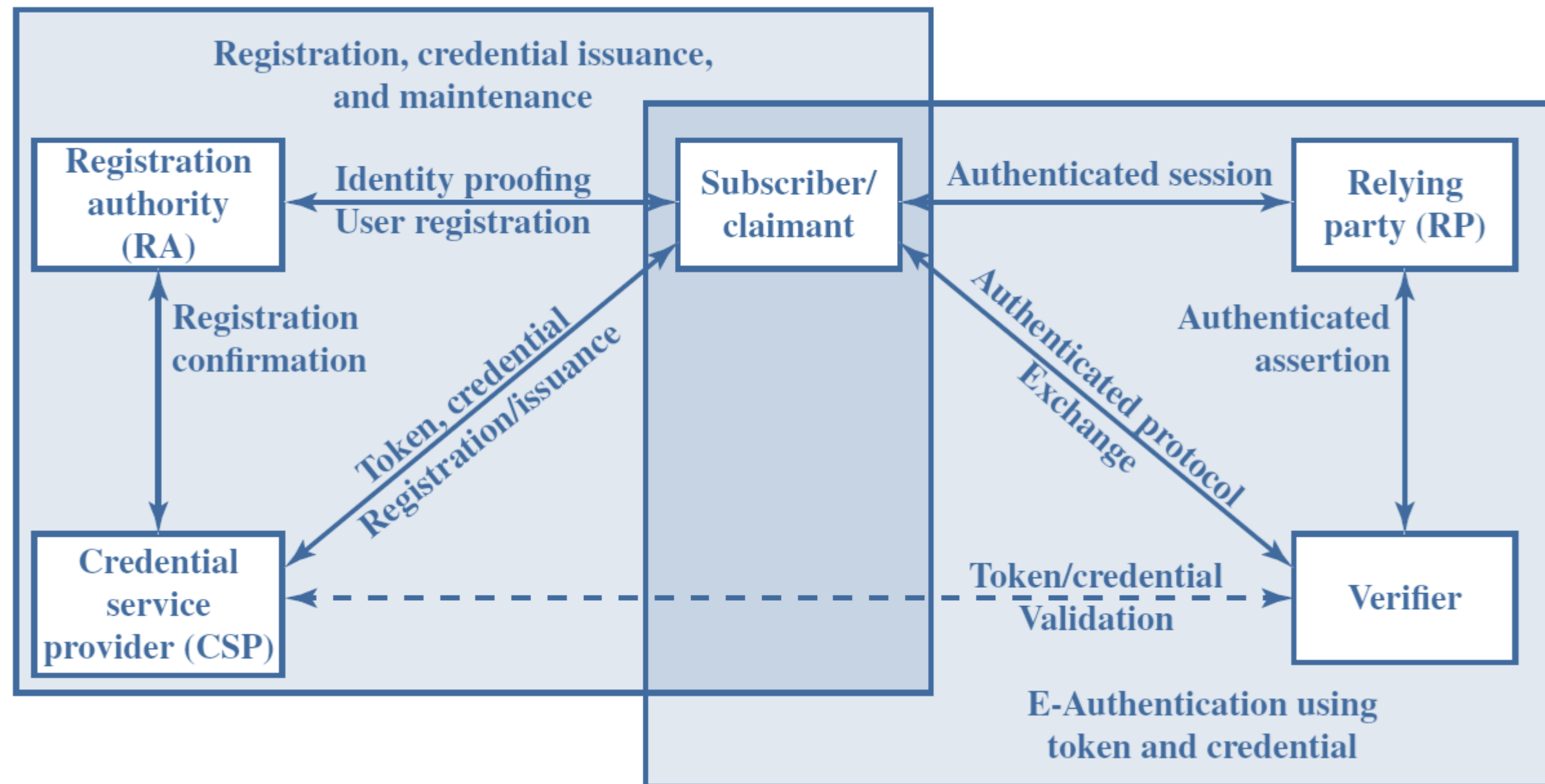
- It involves characteristics whose proof of origin cannot be denied.
- Such characteristics include biometrics like iris pattern, retinal images, and hand geometry and they positively verify the identity of the individual.

2. Repudiable Authentication :

- It involve factors, “what you know” and “what you have”, that can present problems to the authenticator because the information presented can be unreliable because problems including the fact that possessions can be lost, forged, or easily duplicated.

Electronic User Authentication

- The electronic user authentication process, as defined in NIST SP 800-63-2, involves multiple entities and steps to securely establish and verify a user's identity. Here's a detailed explanation of the process:



Electronic User Authentication

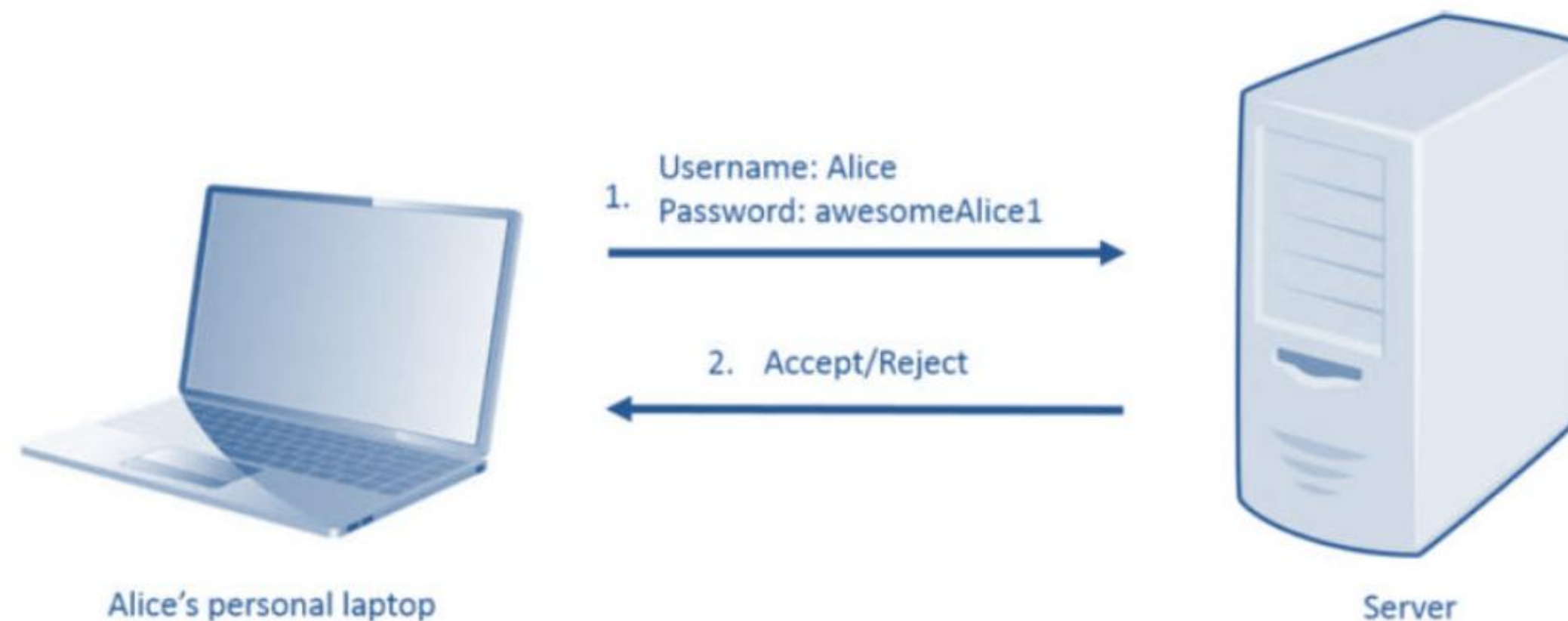
- The initial requirement for performing user authentication is that the user must be registered with the system. The following is a typical sequence for registration.
- An applicant applies to a registration authority (RA) to become a subscriber of a credential service provider (CSP).
- In this model, the RA is a trusted entity that establishes and verify for the identity of an applicant to a CSP.
- The CSP then engages in an exchange with the subscriber. Depending on the details of the overall authentication system, the CSP issues some sort of electronic credential to the subscriber.
- The credential is a data structure that authoritatively binds an identity and additional attributes to a token possessed by a subscriber, and can be verified when presented to the verifier in an authentication transaction. The token could be an encryption key or an encrypted password that identifies the subscriber. The token may be issued by the CSP, generated directly by the subscriber, or provided by a third party. The token and credential may be used in subsequent authentication events.

Electronic User Authentication

- The initial requirement for performing user authentication is that the user must be registered with the system. The following is a typical sequence for registration.
- An applicant applies to a registration authority (RA) to become a subscriber of a credential service provider (CSP).
- In this model, the RA is a trusted entity that establishes and verify for the identity of an applicant to a CSP.
- The CSP then engages in an exchange with the subscriber. Depending on the details of the overall authentication system, the CSP issues some sort of electronic credential to the subscriber.
- The credential is a data structure that authoritatively binds an identity and additional attributes to a token possessed by a subscriber, and can be verified when presented

Password Based Authentication

- A password is an information associated with an entity that confirms the entity's identity.
- It is a string of alphabets, numbers and special characters, which is supposed to be known only to the entity (usually person) that is being authenticated.
- Password based authentication involves authenticating a client (user) by using name and password. The user request the resource controlled by the server. The server requires client authentication before permitting access to the requested resource.



Password Based Authentication

- In response to an authentication request from the server, the client displays a dialog box requesting the user's name and password for that server. The user supply the name and password separately for each new server the user uses during a work session.
- The client sends the name and password across the network, or over an encrypted secure connection.
- The server looks up the name and password in its local password database and, if they match, accepts them as evidence authenticating the user's identity.
- The server determines whether the identified user is permitted to access the requested resource, and if so, allows the client to access it.

Types of Password based authentication

1. **Store password in plain:** Store password in plaintext and use the password for authentication purpose.
2. **Derived from password:** In this type, the server first encrypt the password before storing to the database and uses the same encryption algorithm to compare the password and if matched, then only the users will be authenticated.
3. **Message digest password:** In this type, the message digest is used to create a digest of password and store in the database, and compare the hash using same hashing function to compare if the authentication should be granted or not.

Dictionary Attack

- Dictionary attack is the guessing of password by repeated trial and error.
- A dictionary attack attempts to defeat an authentication mechanism by systematically entering each word in a dictionary as a password or trying to determine the decryption key of an encrypted message or document.
- A dictionary attack can be performed both online and offline.

1. Online Dictionary Attack :

- In online dictionary attack, the attacker tries to guess the correct password by interacting with the login server.
- The attacker repeatedly tries to login or gain access like any other user.
- This type of attack works better if the hacker has a list of likely passwords. If the attack takes too long, it might get noticed by a system administrator or the original user.
- Online attack can be very slow because the speed of attack depends on the speed of the internet connection and the speed of the target server.

2. Offline Dictionary Attack :

- In offline dictionary attack, the attacker first collects message between the users and servers or finds a copy of the password file. Then, the attacker tries to guess correct password by matching the passwords in his dictionary with the collected information without requiring any feedback from the login server.
- Attackers need to get their hands on the password storage file from the system they want to access, so it's more complicated than an online attack. But once they have the correct password, they will be able to log in without anyone noticing.

Password Selection Strategies

- Choosing a strong, secure password is crucial for maintaining security, but it also needs to be memorable for the user. There are 4-basic techniques to achieve this balance.

1. User Education :

- It includes to inform and educate users about the importance of strong passwords and how to create them.
- Providing guidelines and best practices for creating secure passwords.
- Explaining the risks associated with weak passwords, such as being easy to guess or crack.
- Encouraging users to avoid common pitfalls, such as using easily guessable passwords like "password" or "123456."
- Suggesting the use of a mix of uppercase and lowercase letters, numbers, and special characters.
- Advising against using personal information (e.g., names, birthdates) in passwords.

2. Computer-Generated Passwords :

- Generate strong, random passwords that are difficult to guess or crack.
- Using algorithms to create passwords that consist of a random selection of characters.
- Ensuring passwords are sufficiently long and complex to resist brute-force attacks.
- These passwords are often difficult for users to remember.
- Users might be tempted to write them down or store them insecurely.
- Use password management tools to securely store and retrieve complex passwords.

3. Reactive Password Checking

- Identify and prevent the use of weak or easily guessable passwords.
- Implement systems that check passwords against known weak passwords or password patterns.
- Reacting to and flagging weak passwords as they are created or used.
- Check passwords against databases of commonly used or compromised passwords.
- Enforcing policies that reject passwords that don't meet certain criteria (e.g., length, complexity).

4. Complex Password Policy

- To enforce the creation of strong passwords by imposing specific requirements.
- Define rules that passwords must follow, such as minimum length and character diversity.
- Ensuring that passwords include a combination of letters, numbers, and special characters.

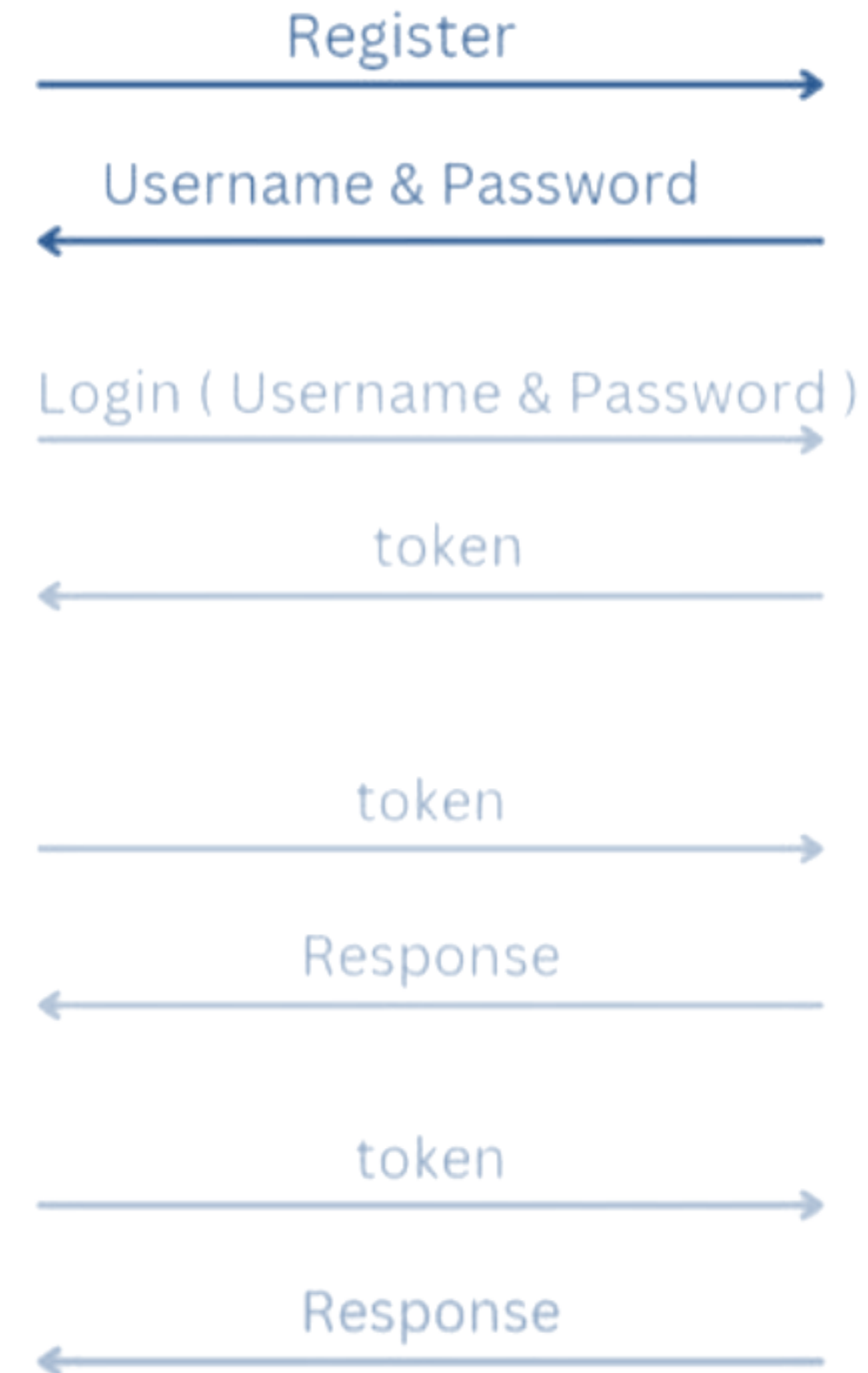
Token Based Authentication

- Token-based authentication is a security mechanism that allows users to verify their identity and gain access to systems and services using tokens rather than traditional methods like passwords.
- Token based authentication is a protocol which allows users to verify their identity, and in turn receive a unique access token.
- During the life of token, users then can access the website or app that the token has been issued for, rather than having to re-enter credentials each time they go back to same web page or app.
- The user retain access as long as the token remains valid. Once the user logs out or quits app, the token is invalidated.
- JWT is one of the example of token based authentication.

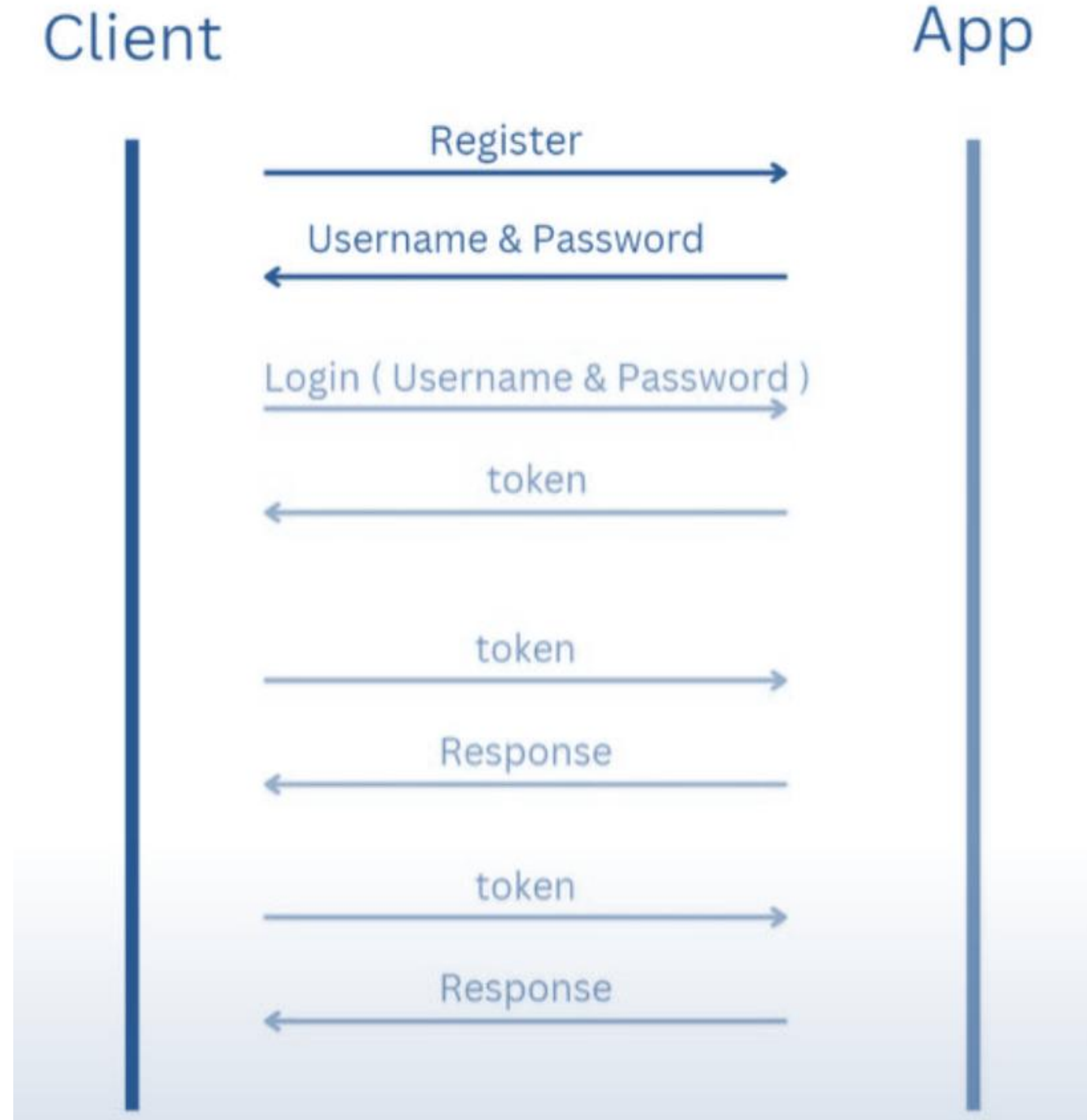
- **Token:** Tokens are digital keys or identifiers that represent the user's identity and permissions. They are typically encoded strings containing encrypted data about the user, such as user ID, roles, and expiration time. Tokens are generated by a server and issued to the client upon successful authentication.
- The user provides their credentials (e.g., username and password) to the authentication server.
- The server verifies the credentials and, if valid, generates a token for the user and send it.
- The client (e.g., web browser or mobile app) stores the token locally, typically in memory, local storage, or a cookie.

Client

App



- When the client needs to access a protected resource, it includes the token in the request header.
- The server receives the request and extracts the token from the header and verifies the token's signature and checks its validity (e.g., expiration time, issuer).
- If the token is valid, the server processes the request and grants access to the resource.
- Tokens usually have an expiration time to enhance security.
- When a token expires, the user may need to re-authenticate to receive a new token.

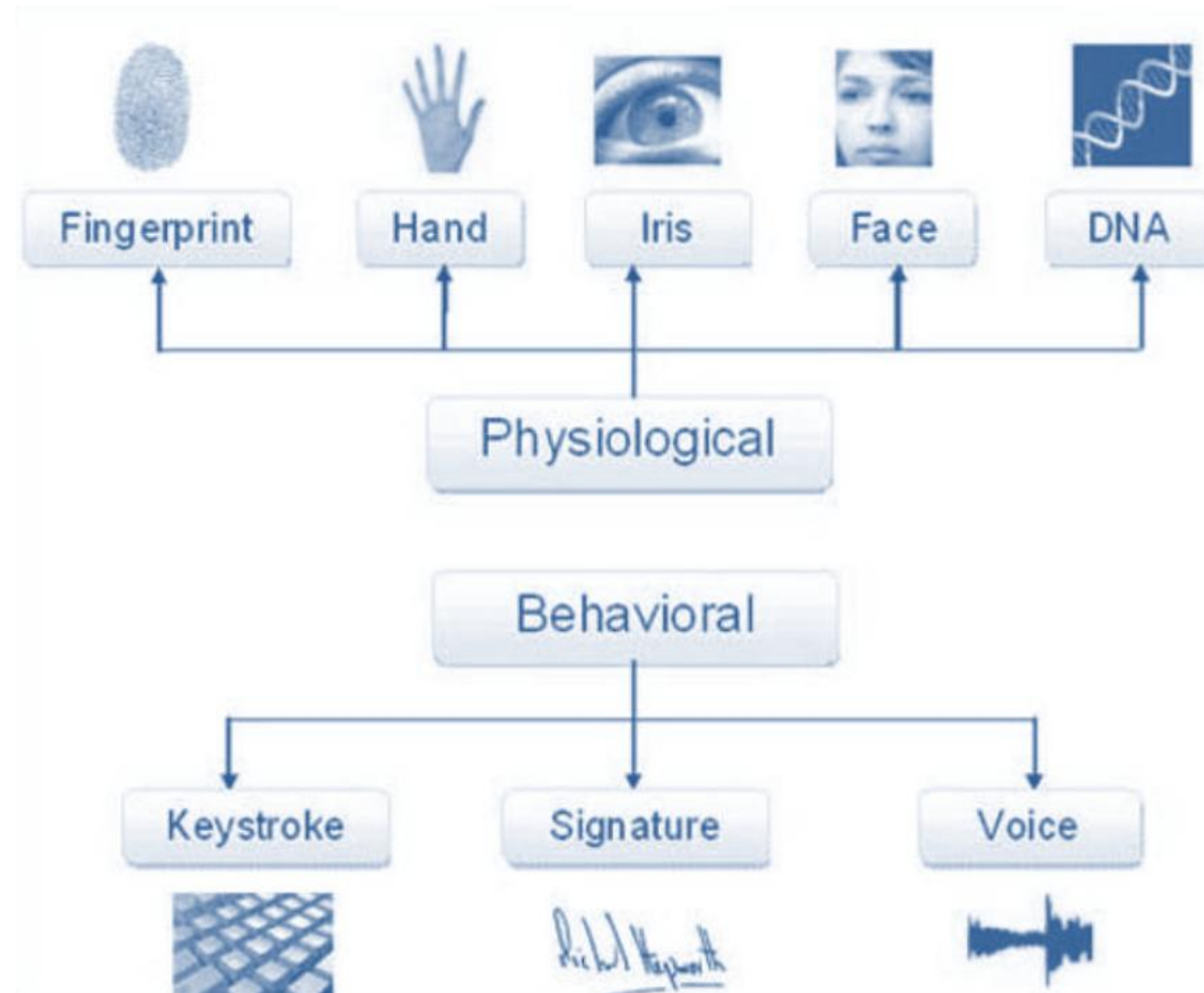


Biometric Based Authentication

- Biometric authentication is a user identity verification process that involves biological input, or the scanning or analysis of some part of the body.
- Whenever the user accesses the system, the biometric authentication mechanism verifies the identity.
- **Process:**
 - The user database contains a sample of user's biometric characteristics.
 - During authentication process, the user is required to provide a new sample of the user's biometric characteristic.
 - This is matched with the one in the database, and if the two samples are same, the user is considered to be a valid one.
 - The sample produced during every authentication process can vary slightly. For example cuts on the finger. So an approximate match can be accepted.

Types of Biometrics

- Biometric characteristics can be divided in two main classes, as shown in figure below :



1. Physiological Biometrics :

➤ Physiological characteristics are related to the shape of the body. This means it is based on our physical attributes.

➤ Example includes:

1. Finger Print Recognition:

The use of the ridges and valleys (minutiae) found on the surface tips of a human finger to identify an individual.

2. Hand Geometry Recognition:

The use of the geometric features of the hand such as the lengths of fingers and the width of the hand to identify an individual.

3. Iris Recognition:

The use of the features found in the iris to identify an individual.

4. Retina Recognition:

The use of patterns of veins in the back of the eye to accomplish recognition.

5. Face Recognition:

6. DNA Matching:

2. Behavioral Biometrics :

➤ The way we speak, type and sign documents are all traits that are unique to every individual. Behavioral characteristics are related to the behavior of a person. Example includes:

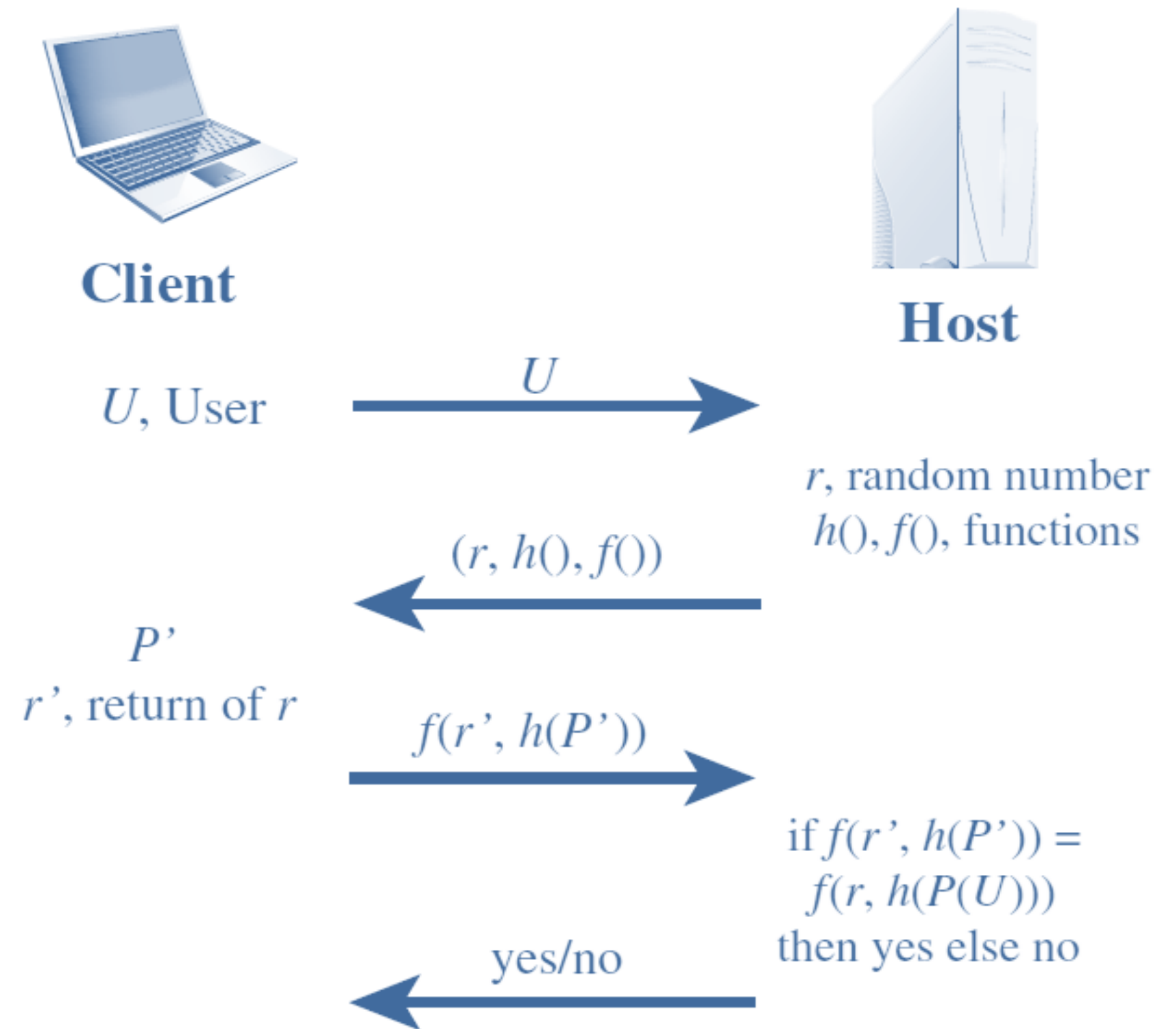
1. **Signature Recognition** : Signature recognition systems will measure and analyze the physical activity of signing, such as the stroke order, the pressure applied and the speed. Some system may also compare visual images of signatures, but the core of a signature biometric system is behavioral, means how it is signed rather than visual or the image of the signature.
2. **Voice Recognition** : Identifies users based on their diction and speech patterns.
3. **Key Stroke Recognition** :
Verifies users based on their typing tendencies, like speed and rhythm.

Remote User Authentication

- Remote User Authentication is a security process that allows users to verify their identity to access a system or network from a different location than the system's physical location.
- The simplest form of user authentication is local authentication, in which a user attempts to access a system that is locally present, such as a stand-alone office PC or an ATM machine. The more complex case is that of remote user authentication, which takes place over the Internet, a network, or a communications link.
- Remote user authentication raises additional security threats, such as an eavesdropper being able to capture a password, or an adversary replaying an authentication sequence that has been observed.
- To counter threats to remote user authentication, systems generally rely on some form of challenge-response protocol.

1. Password Protocol :

- The figure (a) shows the example of a challenge-response protocol used for authenticating a user with a password.

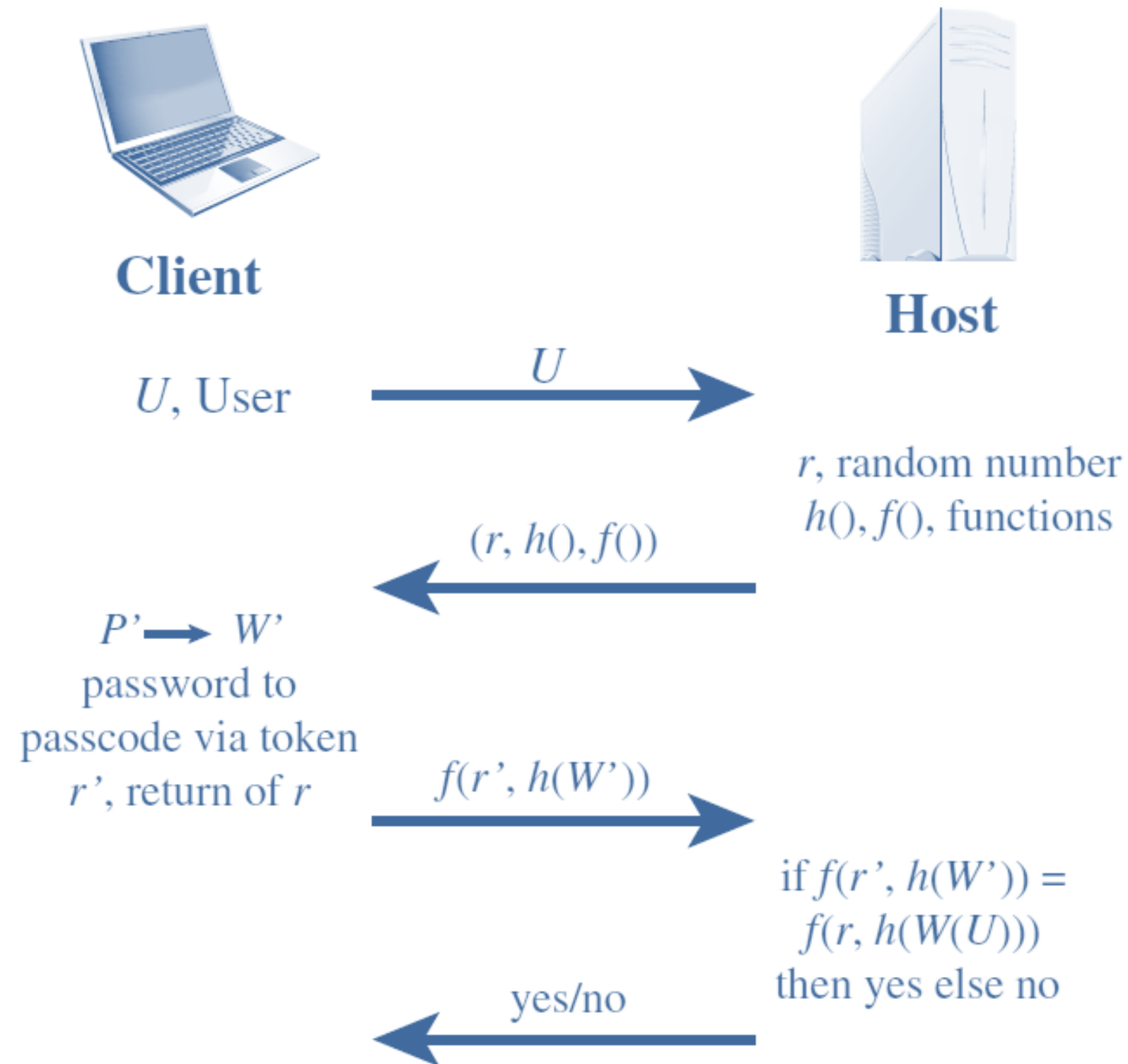


(a) Protocol for a password

1. Password Protocol :

- In this protocol, a user first transmits his or her identity to the remote host. The host generates a random number r , often called a nonce, and returns this nonce to the user. In addition, the host specifies two functions, $h()$ and $f()$, to be used in the response. This transmission from host to user is the challenge.
- The user's response is the quantity $f(r, h(P))$, where P is the user's password. The function h is a hash function, so that the response consists of the hash function of the user's password combined with the random number using the function f .
- The host stores the hash function of each registered user's password, depicted as $h(P(U))$ for user U . When the response arrives, the host compares the incoming $f(r, h(P))$ to the calculated $f(r, h(P(U)))$. If the quantities match, the user is authenticated.

2. Token Protocol :

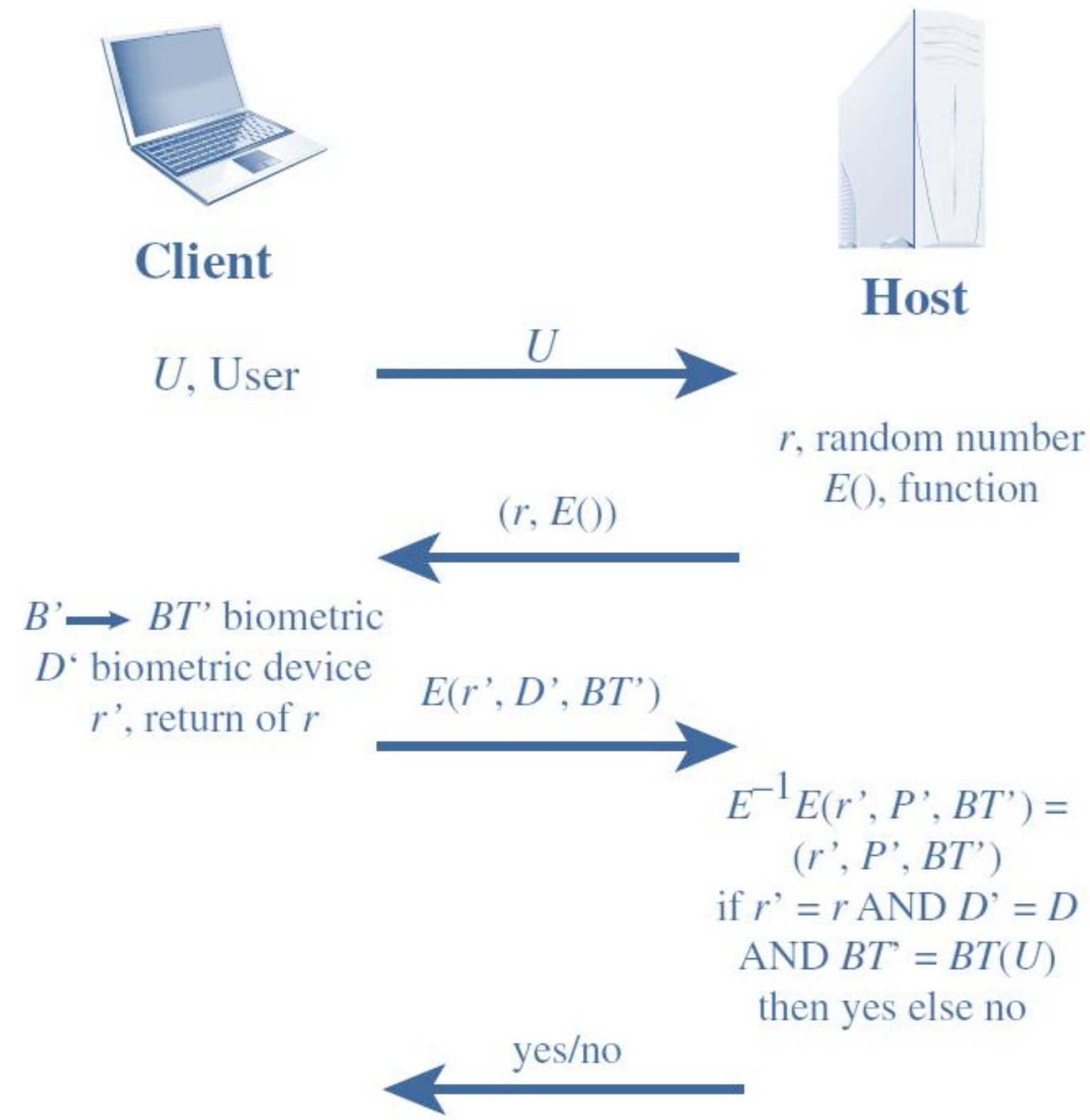


(b) Protocol for a token

2. Token Protocol :

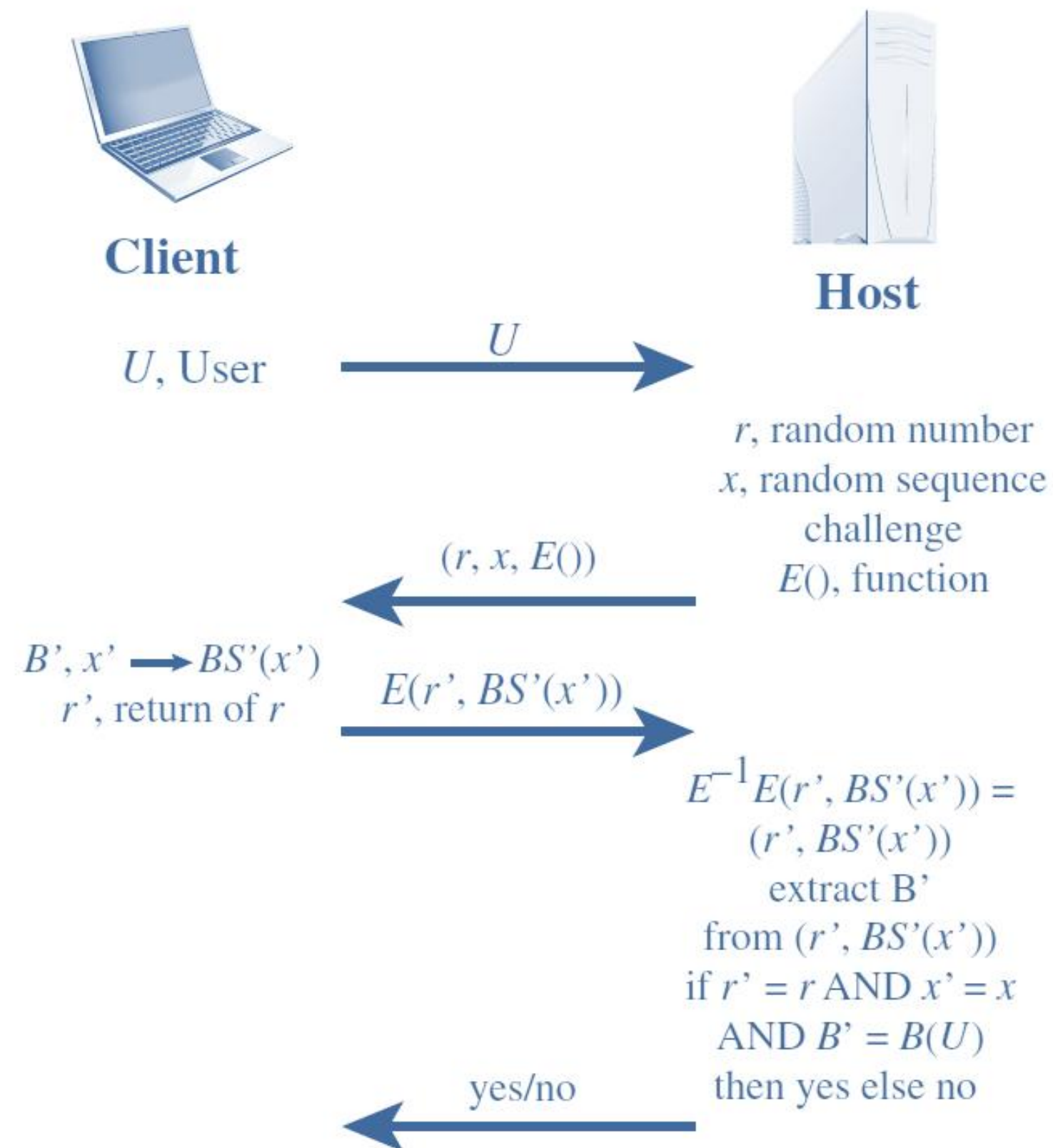
- Figure shows the simple example of a token protocol for authentication.
- As before, a user first transmits his or her identity to the remote host. The host returns a random number and the identifiers of functions $f()$ and $h()$ to be used in the response.
- At the user end, the token provides a passcode W . The token either stores a static passcode or generates a one-time random passcode. For a one-time random passcode, the token must be synchronized in some fashion with the host.
- In either case, the user activates the passcode by entering a password P . This password is shared only between the user and the token and does not involve the remote host. The token responds to the host with the quantity $f(r, h(W))$. For a static passcode, the host stores the hashed value $h(W(U))$; for a dynamic passcode, the host generates a one-time passcode (synchronized to that generated by the token) and takes its hash. Authentication then proceeds in the same fashion as for the password protocol.

3. Static Biometric Protocol :



- Figure shows the user authentication protocol using a static biometric. As before, the user transmits an ID to the host, which responds with a random number r and, in this case, the identifier for an encryption $E()$.
- On the user side is a client system that controls a biometric device. The system generates a biometric template BT from the user's biometric B and returns the ciphertext $E(r, D, BT)$, where D identifies this particular biometric device.
- The host decrypts the incoming message to recover the three transmitted parameters and compares these to locally stored values. For a match, the host must find $r = r$. Also, the matching score between BT and the stored template must exceed a predefined threshold.
- Finally, the host provides a simple authentication of the biometric capture device by comparing the incoming device ID to a list of registered devices at the host database

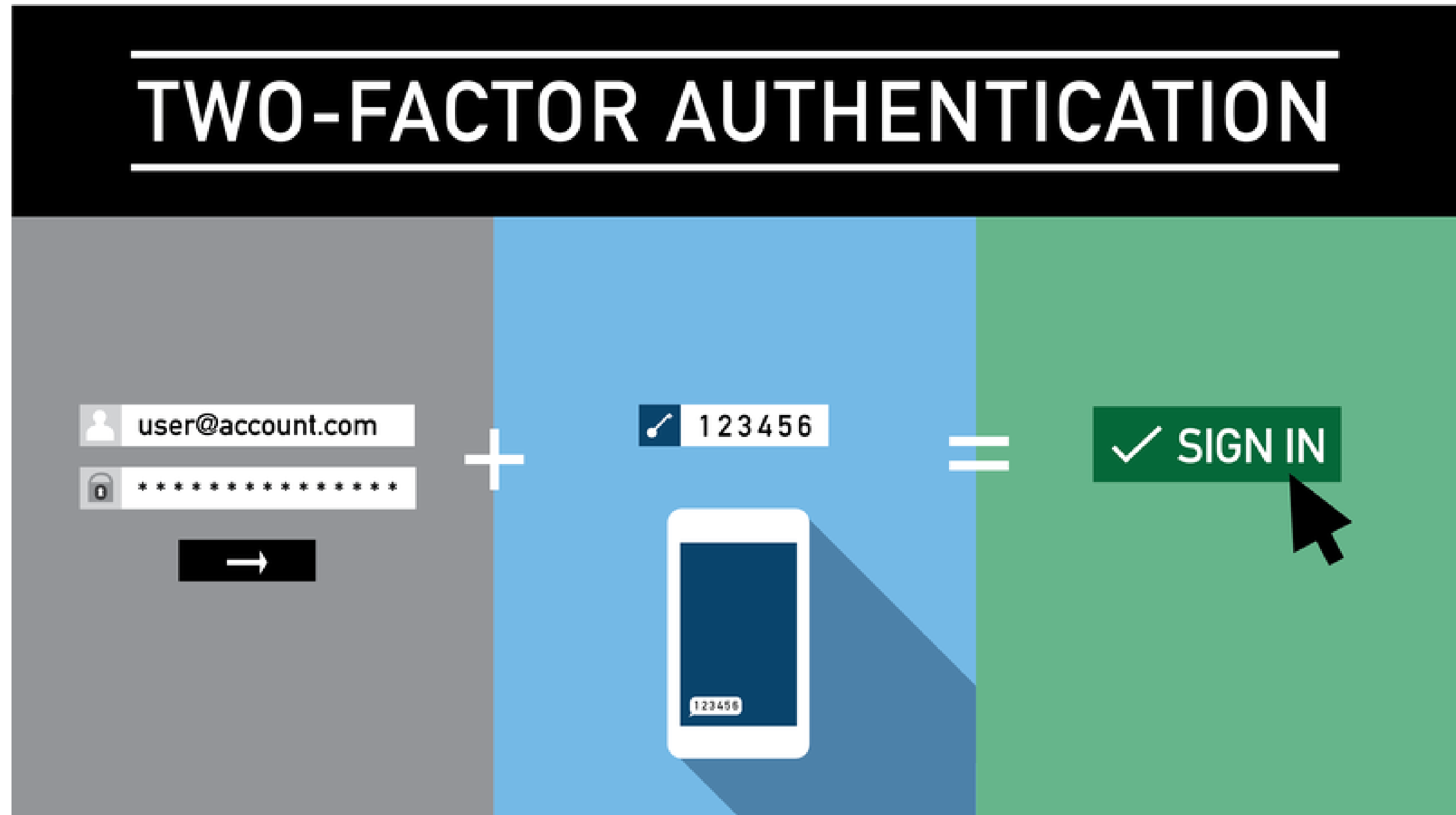
4. Dynamic Biometric Protocol :



(d) Protocol for dynamic biometric

- Figure shows user authentication protocol using a dynamic biometric.
- The main difference from the case of a stable biometric is that the host provides a random sequence as well as a random number as a challenge.
- The sequence challenge is a sequence of numbers, characters, or words. The human user at the client end must then vocalize (speaker verification), type (keyboarddynamics verification), or write (handwriting verification) the sequence to generate a biometric signal $BS(x)$.
- The client side encrypts the biometric signal and the random number.
- At the host side, the incoming message is decrypted. The incoming random number r must be an exact match to the random number that was originally used as a challenge (r).
- In addition, the host generates a comparison based on the incoming biometric signal $BS(x)$, the stored template $BT(U)$ for this user and the original signal x . If the comparison value exceeds a predefined threshold, the user is authenticated.

Two Factor Authentication



Two Factor Authentication

- Two-factor authentication (2FA), sometimes referred to as two-step verification or dual-factor authentication, is a security process in which users provide two different authentication factors to verify themselves.
- 2FA is implemented to better protect both a user's credentials and the resources the user can access. Two-factor authentication provides a higher level of security than authentication methods that depend on single-factor authentication (SFA), in which the user provides only one factor -- typically, a password or passcode.
- Two-factor authentication methods rely on a user providing a password as the first factor and a second, different factor -- usually either a security token or a biometric factor, such as a fingerprint or facial scan.

!!!Thank you!!!